FACTOR

Cédula Digital Dominicana

Mapa de Límites de Seguridad

FACTOR INC. · AUDITORÍA CRIPTOGRÁFICA

projectfactor.io

Cédula Digital Dominicana — Mapa de Límites de Seguridad

Evidencia estructural detallada de las tarjetas examinadas, comparadas frontera por frontera. Las diecisiete fronteras (0–16). Esta comparación estructural detallada describe únicamente esas tarjetas; los hallazgos del firmante de desarrollo RSA-1024 y de la brecha de confianza del CSCA se confirmaron por separado en cédulas de producción (véase los informes de aseguramiento y RSA-1024) y no se generalizan más allá de las tarjetas examinadas a la población emitida completa.

#	Límite	Estado actual	Requisito para superarlo / validarlo	Consecuencia de seguridad
0	Transporte físico	**Superado**	Acceso físico al lector; activación PC/SC y transporte T=1	Solo activación de la tarjeta
1	Descubrimiento público	**Superado**	Acceso ordinario a la tarjeta	Lectura de MF, EF.DIR, EF.ATR/INFO y EF.CardAccess
2	Canal seguro sin contacto	**Superado**	CAN impreso y parámetros PACE	Sesión cifrada autenticada; sin cambio persistente
3	Datos ordinarios de identidad LDS	**Superado**	Sesión segura CAN/PACE activa	Lectura de los datos de identidad permitidos
4	Verificación pasiva de autenticidad	**Parcial**	CSCA de JCE, información de revocación y política de validación	Integridad verificada (firma del SOD válida; 7/7 DG legibles reconcilian con SHA-256); confianza del emisor sin resolver
5	Autenticación del chip	**Superado**	CAN/PACE, suite CA-v1 AES-256/P-384 y ref. de clave 0x30	Posesión probada en vivo; el chip retiene su clave privada no exportable
6	Acceso a huellas dactilares DG3	**Aún no superado**	Cadena CVC autorizada CVCA → DV → terminal (CAR `DOCVCA00001`), clave privada del terminal y derechos DG3	Acceso biométrico de alta sensibilidad; SELECT devuelve 6982 sin EAC-TA
7	Información general PKCS#15	**Superado**	CAN/PACE	SSCD `DomRep SSCDv1`; decodificación completa: el ODF declara los 9 directorios; dos claves privadas no extraíbles (firma + autenticación), seis objetos de autenticación (PIN/PUK), un descriptor de clave 3DES de administración y datos de minidriver están provistos; solo el directorio de certificados (CDF) está vacío
8	Operación de clave general de usuario	**Parcial**	PIN de usuario (ID 05/ref. 83) — retenido y verificado — más un DF de clave operativo	El PIN de usuario verifica (9000), pero la clave 0x42 reside en el DF PKCS#15 (5015), que está en ciclo de inicialización (0x03): INTERNAL AUTHENTICATE devuelve 6982. El uso de la clave lo bloquea el estado del DF, no el PIN
9	Firma SSCD dedicada	**Aún no superado**	Valor del PIN de firma (ref. 92), no entregado al titular, y un certificado	El DF de firma (0DF5) está *operativo* (0x05) y la clave de firma no exportable está presente; bloqueado solo por el PIN de firma no entregado y el certificado ausente
10	Inscripción de certificado ciudadano	**Parcial**	Inscripción de firma electrónica de JCE: verificación de identidad, emisión del certificado y entrega del PIN de firma	El PIN/PUK de firma están provisionados en la tarjeta pero sus valores *no fueron entregados* al titular (el acta de emisión solo traía el PIN de usuario y el PIN SO); sin certificado — la firma digital aún no está inscrita
11	Recuperación de firma	**Aún no superado**	PUK de firma (ID 23/ref. 93) y protocolo autorizado de recuperación	Cambio persistente del estado de la credencial
12	Administración PKCS#15	**Superado**	PIN SO (ID 07/ref. 84)	PIN SO retenido y verificado: acceso administrativo al dominio usuario/5015 (gestiona el PIN de usuario). No alcanza el dominio de firma (0DF5); el PIN de firma lo gobierna el PUK de firma, no el PIN SO
13	Autenticación administrativa externa	**Aún no superado**	Secreto administrativo 3DES de 192 bits (ref. 0x21) y protocolo reto–respuesta	Objeto de clave observado en el SKDF (authId 07); su uso requiere el secreto, que no se posee
14	Hijos propietarios DomRepEID	**Superado**	CAN/PACE; seleccionar el AID DomID	Barrido de solo lectura (SFI 1–30): el DF se mapea al MF y reexpone solo archivos públicos (EF.ATR/INFO, EF.CardAccess, EF.CardSecurity, EF.DIR); sin datos personales ni secretos nuevos
15	Gestión GlobalPlatform / JCOP	**Aún no superado**	Claves del Dominio de Seguridad del emisor, configuración SCP y privilegio de gestión	Control de applets, privilegios y ciclo de vida
16	Fabricación / personalización	**Aún no superado**	Perfil de proveedor, claves del emisor, autoridad HSM/SAM y sistemas de producción	Creación o reemplazo de objetos de seguridad; autoridad destructiva del emisor

LEYENDA DE COLORES

Superado	Parcial	Aún no superado	Incompleto	Desconocido
Leído por completo con solo la tarjeta física y la información impresa en ella (o, en 12, con un PIN entregado al titular).	La prueba avanzó sin credenciales del emisor, pero no confirma toda la capa.	Aún no superado en esta prueba; requiere un secreto del emisor o un certificado que no se posee.	La función parece no estar configurada en las tarjetas observadas.	No hay evidencia accesible suficiente para determinar su estado.

Evidencia de la cédula de producción independiente. Las fronteras 2, 3 y 5 se ejercieron en vivo sobre una cédula de producción: se estableció CAN/PACE, se leyeron los grupos de datos de identidad y se completó la Autenticación del Chip (posesión de la clave privada no exportable probada). Frontera 4: la firma CMS del EF.SOD es válida y los siete grupos de datos legibles (1, 2, 7, 11, 12, 13, 14) reconcilian con el SOD bajo SHA-256; la confianza del emisor sigue sin resolver porque el CSCA de cédula de JCE no es recuperable (el host de distribución `ca.jce.gob.do` responde NXDOMAIN — reconfirmado con una consulta en vivo; el mismo host sirve el punto de distribución de CRL del DS, por lo que la verificación de revocación es igualmente inalcanzable). Una decodificación por registros completos de la frontera 7 (que corrige una lectura truncada previa) muestra que la tarjeta está totalmente personalizada: el ODF declara los nueve directorios; el PrKDF tiene dos claves privadas no exportables (firma, ref. 0x41, PIN de firma; autenticación, ref. 0x42, PIN de usuario); el AODF tiene seis objetos de autenticación y una consulta de estado en vivo confirma que cada PIN/PUK está establecido (SO, usuario, PIN de firma y PUK de firma, con contadores de reintento completos); y la clave 3DES de administración y los datos de minidriver están presentes. El único elemento ausente es el certificado X.509 en tarjeta (CDF vacío), también vacío en otras tarjetas examinadas — probablemente se mantiene fuera de la tarjeta o está pendiente, no es una carencia por tarjeta. Toda frontera alcanzable sin un secreto del emisor ni un certificado verificable por la tarjeta (0–5, 7, 14) se ha leído por completo; el resto requiere credenciales en poder de la JCE.

Evidencia de credenciales y ciclo de vida. Los dos códigos del acta de emisión se correlacionaron con el chip: el "PIN (inicial)" es el **PIN de usuario** (ref. 83) y el "PUK" es el **PIN SO** (ref. 84) — ambos retenidos y verificados (9000); el PIN SO abre la frontera 12 (administración del dominio usuario/5015) pero no tiene derechos en el dominio de firma. El **PIN de firma (ref. 92) y el PUK de firma (ref. 93) están provisionados** (una consulta de estado devuelve contador de reintentos, y los intentos erróneos lo decrementan — hay un valor almacenado), pero sus valores *nunca se entregaron al titular*, y no hay certificado. El ciclo de vida está dividido: el DF de firma `0DF5` (clave de firma, PIN y PUK de firma) está **operativo (0x05)**, mientras que el DF PKCS#15/autenticación `5015` (clave de autenticación, PIN de usuario y PIN SO) está en **inicialización (0x03)**. En consecuencia, la clave de firma *no* la bloquea ningún estado de ciclo de vida — solo el valor no entregado del PIN de firma y el certificado ausente (frontera 9) — mientras que la clave de autenticación falla con 6982 porque su DF sigue en inicialización (frontera 8). En conjunto: la *firma electrónica* aún no está inscrita; sus ranuras de PIN están preprovisionadas, pero las credenciales y el certificado deben provenir de un paso de inscripción de firma de la JCE.

Contadores de reintento en vivo (consulta no mutante, nunca consumidos): PIN SO 5/5, PIN de usuario 3/3, PIN de firma 3/3, PUK de firma 5/5. Fuente: el registro interno detallado del mapa de límites del proyecto (no incluido en este repositorio publicado) y el conjunto de herramientas `tools/active_adaptive/`.